Vježbe – PHP/MySQL sigurnost i SQL injection

Prvi dio

Cilj: Pokazati kako nesiguran kod može biti iskorišten.

1. SQL injection

- ✓ **Pokrenuti wampserver**
- ✓ **Pokrenuti phpmyadmin alat**
- ✓ **Kreirati tabelu korisnici sa poljima id, username i password**

```
use edukacija;
CREATE TABLE KORISNICI(
  id int not null AUTO_INCREMENT primary key,
  username varchar(40),
  password varchar(40)
)
```

Kroz phpmyadmin dodati unos username i password.

- Kreirati folder **prvi_primjer.**
- Napraviti jednostavnu login formu (login.html) sa poljima username i password unutar kreiranog foldera **prvi_primjer**.

Login forma **login.html** ima sljedeći kod:

```html
<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <title>Login Form</title>
</head>
<body>
  <h2>Login</h2>
  <form action="login_insecure.php" method="post">
    <label for="username">Username:</label><br>
    <input type="text" id="username" name="username" required><br><br>

    <label for="password">Password:</label><br>
    <input type="password" id="password" name="password" required><br><br>

    <button type="submit">Login</button>
  </form>
</body>
</html>
```

- ✓ *Kreirati dva php fajla, jedan u kojem koristimo nesiguran način spajanja sa bazom podataka i drugi u kojem koristimo siguran način spajanja.*

Prvi php fajl **login_insecure.php** je sa nesigurnim načinom povezivanja sa bazom podataka.

U PHP skripti (**login_insecure.php**) koristiti **nesiguran** način spajanja:

```
<?php
$conn = mysqli_connect("localhost", "root", "", "edukacija");
$username = $_POST['username'];
$password = $_POST['password'];

$sql = "SELECT * FROM korisnici WHERE username='$username' AND password='$password'";
$result = mysqli_query($conn, $sql);
if(mysqli_num_rows($result) > 0) {
    echo "Dobrodošli na svoj profil!";
} else {
    echo "Pogrešni podaci.";
}
?>
```

Testirati sljedeći unos kroz formu:

> **Username:** admin
>
> **Password:** ' OR '1'='1

Kao rezultat prijava treba da uspijeva bez tačnog password-a.

2. Sigurna verzija sa (PDO) načinom pristupa bazi podataka

Cilj: Naučiti kako spriječiti **SQL injection** napad na bazu podataka.

Kopirati **login.html** i preimenovati u **login_secure.html**. U **action** atribut forme unutar **login_secure.html** staviti naziv sljedeće datoteke **login_secure.php**. U nastavku se nalazi kod za php datoteku koja se poziva nakon klika na submit dugme.

Kreirati datoteku **login_secure.php** sa sljedećim sadržajem:

```
<?php
$pdo = new PDO("mysql:host=localhost;dbname=edukacija", "root", "");
$pdo->setAttribute(PDO::ATTR_ERRMODE, PDO::ERRMODE_EXCEPTION);
$username = $_POST['username'];
$password = $_POST['password'];

$sql = "SELECT * FROM korisnici WHERE username = :username AND password = :password";
$stmt = $pdo->prepare($sql);
$stmt->execute([
    ':username' => $username,
    ':password' => $password
]);
if($stmt->rowCount() > 0) {
    echo "Dobrodošli!";
} else {
    echo "Pogrešni podaci.";
```

```
}
?>
```

3. Validacija podataka

Zadatak: kao dodatni kod može se dodati kod za validaciju unosa:

- Provjeriti da username sadrži samo slova i brojeve (ctype_alnum).
- Provjeriti da password ima minimalno 8 znakova.
- Ako validacija ne prođe, ne izvršavati SQL upit.

```
// Validacija unosa podataka
if(!ctype_alnum($username)) {
    die("Korisničko ime smije sadržavati samo slova i brojeve.");
}

//dužina unesenog password-a da bude najmanje 8 znakova
if(strlen($password) < 8) {
    die("Password mora imati najmanje 8 znakova.");
}
```

4. Vježba – simulacija napada

Zadatak: Testirati nekoliko unosa na nesigurnoj verziji:

- ' OR '1'='1
- admin' --
- '; DROP TABLE korisnici; --

Potom testirati iste unose na sigurnoj verziji i pokazati da napad ne uspijeva.

Drugi dio

5. Kreirati novu tabelu u bazi edukacija za testiranje primjera gdje password koristi hashing.

```
use edukacija;
CREATE TABLE users(
  id int not null AUTO_INCREMENT primary key,
  username varchar(40),
  password varchar(40)
)
```

6. Kreirati u novom folderu **drugi_primjer** novi fajl **login_novi.html** koji će u **action** atributu pozivati **login.php** skriptu.

login_novi.html

```
<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <title>Login Form</title>
</head>
<body>
  <h2>Login</h2>
```

```
  <form action="login.php" method="post">
    <label for="username">Username:</label><br>
    <input type="text" id="username" name="username" required><br><br>

    <label for="password">Password:</label><br>
    <input type="password" id="password" name="password" required><br><br>
    <button type="submit">Login</button>
  </form>
</body>
</html>
```

login.php ima sljedeći sadržaj:

```
<?php
$conn = new PDO("mysql:host=localhost;dbname=edukacija", "root", "");
$conn->setAttribute(PDO::ATTR_ERRMODE, PDO::ERRMODE_EXCEPTION);

if ($_SERVER["REQUEST_METHOD"] == "POST") {
    $username = $_POST['username'];
    $enteredPassword = $_POST['password'];

    // Dohvatiti hash iz baze
    $sql = "SELECT password FROM users WHERE username = :username";
    $stmt = $conn->prepare($sql);
    $stmt->bindParam(':username', $username, PDO::PARAM_STR);
    $stmt->execute();

    $storedHash = $stmt->fetchColumn(); // uzmi vrijednost iz kolone "password"

    // Provjera password-a
    if ($storedHash && password_verify($enteredPassword, $storedHash)) {
        echo "Dobrodošao, $username!";
    } else {
        echo "Pogrešan unos.";
    }
}
?>
```

7. Kreirati formu za registraciju korisnika tako što ćemo kreirati **register.html** fajl, a unutar njega pozvati u action atributu u formi **register.php**.

Register.html

```
<!DOCTYPE html>
<html lang="hr">
<head>
    <meta charset="UTF-8">
    <title>Registracija</title>
</head>
<body>
    <h2>Registracija korisnika</h2>
```

```
    <form action="register.php" method="post">
        <label for="username">Korisničko ime:</label>
        <input type="text" name="username" id="username" required><br><br>

        <label for="password">Password:</label>
        <input type="password" name="password" id="password" required><br><br>

        <button type="submit">Registriraj se</button>
    </form>
</body>
</html>
```

Register.php

```
<?php
$conn = new PDO("mysql:host=localhost;dbname=edukacija", "root", "");
$conn->setAttribute(PDO::ATTR_ERRMODE, PDO::ERRMODE_EXCEPTION);

if ($_SERVER["REQUEST_METHOD"] == "POST") {
    $username = $_POST['username'];
    $password = $_POST['password'];

    // Hashiranje password-a
    $hashedPassword = password_hash($password, PASSWORD_DEFAULT);

    // Spremanje u bazu
    $sql = "INSERT INTO users (username, password) VALUES (:username, :password)";
    $stmt = $conn->prepare($sql);
    $stmt->bindParam(':username', $username, PDO::PARAM_STR);
    $stmt->bindParam(':password', $hashedPassword, PDO::PARAM_STR);
    $stmt->execute();

    echo "Registracija korisnika je uspješna!";
}
?>
```

←T→				id	username	password
☐	Edit	Copy	Delete	3	User	$2y$10$5SgQ5eH9yuxPBJ3NO8dw1eG6G7JKKVAhY

8. Uraditi integraciju login i register unutar prethodne vježbe.